Ref. Ares(2026)8344648 - 01/09/2026

# APPENDIX 2

# I. SECURITY REQUIREMENTS FOR EUROPEAN UNION AVIATION SAFETY AGENCY's (THE AGENCY) CONTRACTORS

For the purpose of Appendix *2* on Security Requirements, the following definitions apply:

**'Security incident':** any event having or threatening to have an adverse effect on the security of network and information systems, including but not limited to a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of or access to data, including but not limited to personal data, transmitted, stored or otherwise processed;

**'Service provider'**: an individual member of the personnel of the contractor providing a service to the contracting authority under the FWC and/or the specific contracts.

## I.1. SECURITY MANAGEMENT

### I.1.1. Compliance with the applicable security requirements

When performing tasks for the contracting authority in execution of the FWC and/or the specific contracts, the contractor and its personnel (service providers) shall comply with the contracting authority's applicable security requirements.

For the Agency, the applicable security requirements include the Agency's security rules adopted on the basis of Article 123 of Regulation (EU) 2018/1139, under which the Agency shall adopt its own security rules equivalent to the Commission's security rules set out in Commission Decisions (EU, Euratom) 2015/443 and (EU, Euratom) 2015/444. While these Commission Decisions may serve as a benchmark, the Agency will inform the contractor of the rules applicable to the Agency at the time of execution of the contract.

In the cybersecurity domain, the Agency adopted PO.ISM.00003 EASA Cybersecurity Policy which describes how Regulation (EU, Euratom) 2023/2841 of the European Parliament and of the council of 13 December 2023 laying down measures for a high common level of cybersecurity at the institutions, bodies, offices and agencies of the Union is implemented at EASA. The contractor and its personnel (service providers) shall comply with this policy and its subsequent versions, its implementing rules (the latest version) and the corresponding security standards, guidelines and notices.
The Agency will inform the contractor of the rules applicable to the Agency at the time of execution of the contract.

The applicable security requirements may be further defined and detailed in the specific contract. In the case of an interinstitutional FWC, each contracting authority may include security requirements on the security management, information security management, security incident management and security assessment obligations provided in Articles I.1, I.2, I.3 and I.4, as applicable, in the provisions of specific contracts in accordance with rules governing the functioning of the contracting authority and relevant legislation.

The contractor is responsible for establishing and maintaining an appropriate risk management process for ensuring the confidentiality, integrity and availability of assets. This process should encompass the implementation of suitable technical and organizational security measures before commencing any tasks in execution of the FWC. The contractor shall appropriately maintain such measures for the duration of the FWC and shall update the measures at regular

intervals based on the state of the art, the evolving risks and changes in the Agency's security requirements.

When determining the appropriate technical and organisational security measures, the contractor shall notably take into account:

- the state of the art;
- the nature, scope, context and purposes of processing, including but not limited to collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction of information and/or data; and
- the risks, including but not limited to those deriving from accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to information and/or data transmitted, stored or otherwise processed.

The contractor shall take all appropriate steps for each supplied product or service to ensure that the data and/or information, the information systems and the media upon which they are stored are safely preserved. The supplied products and services shall not contain any vulnerability which could compromise their availability, integrity or confidentiality or that of the contracting authority's evolving multi-manufacturer information technology environment, architecture and physical premises. In the event that any critical vulnerability able to compromise the security of the supplied products or services is identified, the contractor shall immediately inform the contracting authority and proceed with the remediation of said vulnerability at its own cost.

The contractor shall ensure that all security precautions for each supplied product or service are clearly set out in the relevant documentation supplied to the contracting authority.

In some cases, when required for security reasons, the contracting authority may ask the contractor to provide "security cleared personnel". This will be considered as a specific requirement for a specific project, without influencing the other conditions.

If requested by the contracting authority, the contractor shall ensure that any person involved in the provision of the services under this FWC attends the security briefings or training given by the contracting authority, and/or signs the relevant security statement.

In case the contractor's service providers (personnel) are granted access rights to the contracting authority's premises and/or are granted access to communication and information systems of the contracting authority or data sets processed therein, the contractor should ensure that each service provider performing tasks for the contracting authority in execution of the FWC and/or specific contracts signs the declaration in Annex I (Ethics Reminder for Service Providers Working for the Contractor – to be included by the contractor in the contract concluded with its service provider) and then confirms to the contracting authority before the start of the performance of the services that it has been signed.

Upon request, the contractor must provide evidence to the contracting authority that the obligations of this paragraph have been passed on to its subcontractors and personnel and that the required declarations have been signed.

The contractor undertakes to impose the security management, information security management, security incident management and security assessment obligations provided in Articles I.1, I.2, I.3 and I.4 of this document, as applicable, upon its personnel in the relevant contracts signed with them.

The contractor shall document all measures and mechanisms implemented to comply and demonstrate compliance with the applicable security requirements and shall make such information available to the contracting authority upon the latter's first request.

Any costs for complying with the applicable security requirements (e.g. security background checks, screening fee, security clearance, information security management, security incident management etc.) will be entirely at the expense of the contractor and not of the contracting authority.

### I.1.2. Protecting EU classified information

When access to EU classified information is granted in the context of the services provided under the present contract, the contractor and its personnel shall comply with the contracting authority's applicable rules on EU classified information.

For the Agency, the Agency's security rules adopted on the basis of Article 123 of Regulation (EU) 2018/1139, under which the Agency shall adopt its own security rules equivalent to the Commission's security rules set out in Commission Decisions (EU, Euratom) 2015/443 and (EU, Euratom) 2015/444. While these Commission Decisions may serve as a benchmark, the Agency will inform the contractor of the rules applicable to the Agency at the time of execution of the contract.

### I.1.3. Specific security rules for the contractor's[1] personnel

For the Agency, the Agency's security rules adopted on the basis of Article 123 of Regulation (EU) 2018/1139, under which the Agency shall adopt its own security rules equivalent to the Commission's security rules set out in Commission Decisions (EU, Euratom) 2015/443 and (EU, Euratom) 2015/444. While these Commission Decisions may serve as a benchmark, the Agency will inform the contractor of the rules applicable to the Agency at the time of execution of the contract.

Article I.15 of the FWC and EASA's Physical Security policy (PO.FACIL.00034) provide the framework for a physical security system, controls, mitigating measures and guidance that must be followed.

### I.1.4. Security of communication and information systems of the contracting authority

*[Option 1: no access to CIS is granted to contractor's personnel*

No access for contractor's personnel to communication and information systems of the contracting authority or data sets processed therein will be granted in the context of the services provided under the present contract.]

*[Option 2: access to CIS is granted to contractor's personnel*

In the context of the services provided under the present contract, contractor's personnel will be granted access to communication and information systems of the contracting authority or

[1] The notion of contractors used in this clause has the same meaning as the notion of external contractors used in the screening Memorandum of Understanding.

data sets processed therein using either IT equipment provided by the contracting authority (normally a laptop PC) or IT equipment of the contractor.

When performing tasks for the contracting authority on its communication and information systems (CIS), on the internal network or in outsourced environments in execution of the contract, the contractor and its personnel shall comply with the contracting authority's applicable security requirements which, in the case of EASA include the PO.IS.00052 – Allocation and acceptable use of IT equipment, its subsequent versions, its implementing rules (the latest version) and the corresponding security standards, guidelines and notices.

In case the contractor, during the performance of the tasks which are the subject of the contract, needs remote access to any communication and information system of the contracting authority or data sets processed therein, the contractor is required to put in place the necessary security measures in order to mitigate risks to the security of the contracting authority's information during the fulfilment of the contracted services, for which the following rules apply. The contractor and its service providers shall comply with the contracting authority's applicable security baseline, which includes the Security Baseline for External Connections – Rules for Contractors and service providers (EASA Security Baseline, Appendix 3 of this contract).

EASA Security Baseline includes rules that are applicable for all categories of service providers using remote access and in all scenarios, covering the handling of EASA information in transit and at rest on IT equipment or infrastructure used by service providers (including EASA or contractor laptops, EASA networks and CISs to which they connect, and any removable media supplied by EASA).

Additional rules apply when the target CIS (system, service or infrastructure) is not accessible by default via external gateways and requires a custom interconnection (covered by an additional Interconnection Security Agreement (ISA)).

The EASA Security Baseline apply to service providers working on contractor's premises or in home offices, where permitted by the contract. Any remote service delivery site for a service provider shall be located in an EU Member State.

Service providers must sign the Individual Service Provider Security Commitment annexed to the EASA Security Baseline.

The EASA Security Baseline does not cover service providers accessing non-EASA systems, such as contractors' development environments, or the handling of EASA information in non-EASA repositories or systems.

## I.2. INFORMATION SECURITY MANAGEMENT

When performing tasks for the contracting authority, the contractor shall handle any information related to those tasks by applying accordingly the rules provided in the FWC on localisation of and access to personal data. For specific categories of information this article provides for more restrictive rules that will be applicable for the contractor in addition to the rules of the FWC.

Documents marked as EASA Normal and Sensitive Non-classified Information must be hosted only in EU Member States.

For any information related to the implementation of the FWC that is stored in the contractor's information systems the contractor shall guarantee that:

- Information is available and usable when required (availability);
- Information is only accessed by or disclosed to individuals who have the right to know (confidentiality);
- Information is complete, accurate, and protected against unauthorized modification (integrity);
- Business transactions, as well as information exchanges, can be trusted (authenticity and non-repudiation).

If the contractor handles non-public information of the contracting authority in their IT systems they must follow a risk-based approach in order to ensure the protection of the information at the appropriate level.

The contractor must not disclose or grant access to any information or equipment provided by the contracting authority or delivered to the contracting authority in the implementation of the FWC (such as operating procedures, system designs, configurations, etc.), actively or passively, intentionally or negligently, to any third parties.

In case of receipt of a legally binding request for disclosure of the data processed on behalf of the contracting authority, the contractor shall treat non-personal data in the same way as they shall treat personal data under the provisions applicable to personal data in this FWC.
The contractor and its personnel shall be aware of the applicable contracting authority's security rules relating to their activities, the level of confidentiality of the information that they handle, and any relevant handling instructions (notably in the case of the Agency for sensitive non-classified (SNC) information, The relevant instructions applicable at the time of the execution of the contract will be made available by the Agency to the contractor.

## I.3. SECURITY INCIDENT MANAGEMENT

The contractor shall implement the necessary organisational and technical measures and mechanisms to prevent, detect, and handle any security incident in an appropriate manner. The contractor shall regularly re-assess and update the implemented measures and mechanisms in light of the state of the art and the risks, which may evolve over time in light of the evolution in the technologies relevant for the implementation of the FWC.

In the event a security incident occurs or has occurred in implementation of this FWC, the contractor shall, irrespective of the level of risk, notify the contracting authority thereof without undue delay and not later than 48 hours after becoming aware of the security incident, except in the event the contractor is made aware by the contracting authority. The contractor shall enquire the contracting authority about appropriate notification channels latest at the start of the contract implementation.

In the context of any notification made in compliance with this article or upon the contracting authority's first request, the contractor shall provide the contracting authority with at least the following information:

- Nature of the security incident including where possible, the categories and approximate number of data records concerned and, where applicable, the categories and approximate number of data subjects concerned;
- Exact date or period of the security incident as well as date and time of detection;
- Explanation on how the security incident was detected, its root cause and its likely and/or actual consequences; and
- Measures taken or proposed to be taken to address the security incident, including, where appropriate, measures to mitigate its possible adverse effects.

When personal data is affected by the security incident, the Data Protection Officer of the contracting authority must be put in copy of the notification.

The contractor shall use its best efforts to assist the contracting authority with the notification of the security incident to the competent authority(ies) and/or the data subject(s) where applicable. In particular, the contractor shall co-ordinate with, and assist the contracting authority with sharing information about security incidents, vulnerabilities and cyber threats with CERT-EU, whenever the contracting authority opts to do so.

In the event of a security incident, the contractor shall take all measures necessary and appropriate to limit the negative impact of the security incident as much as possible (including but not limited to the provision of forensic assistance to the contracting authority), to mitigate damages and to establish appropriate monitoring mechanisms for the future.

## I.4. SECURITY ASSESSMENT

The contractor shall fully collaborate in assessing and/or auditing its compliancy to the applicable IT security frameworks and regulations, where applicable.

This collaboration will cover, among others:

- performing and maintaining detailed internal IT security risk management;
- the participation in IT risk assessments performed by the contracting authority and related to the services provided by the contractor, including yearly revision;
- the participation in IT audits and/or security inspections imposed by the relevant internal services of the contracting authority (internal audit services, security directorate, etc.);
- the participation in Regulation (EU) 2016/679 or Regulation (EU) 2018/1725 compliance audits performed by the European Data Protection Supervisor (EDPS) and, based on the results of those assessments and audits, the implementation of identified security measures in case of non-compliance with EU regulations and/or IT security standards;
- when inducing changes in the infrastructure or in the service, the timely sharing of information about these changes and their impact on security, availability and data protection.

To fulfil this obligation, the contractor will identify internally an IT security manager, who will become the point of contact with the contracting authority with regard to the coverage of those activities and the fulfilment of the related obligations.

It is to be noted that this IT security manager is to be understood as a role, and not as an assignment to a single person. This implies respective back-up provisions, knowledge transfer and other organisational provision within the people assigned to this role.

Upon request from the contracting authority, within 14 days the contractor shall provide the contracting authority with the identity of the IT security manager.

The IT security manager is entitled to designate delegations to follow-up on specific projects and tasks; nevertheless the IT security manager will remain responsible for the execution of all his tasks (including those that have been delegated). The contracting authority will be informed of each such delegation, as soon as it occurs.

This IT security manager will participate in the different meetings organised by the contracting authority on these topics and will provide the necessary documents in relation with the domains covered. When requested, the IT security manager will also attend the service review meetings or other ad hoc meetings during which these aspects will be addressed.

The contractor commits to collaborate with the contracting authority's security teams in all questions regarding security governance, management and reporting, including their requests as concerns selection and hardening of equipment and security scans.

## I.5. SECURITY OF OUTSOURCING OF COMMUNICATION AND INFORMATION SYSTEMS (CIS) OF THE CONTRACTING AUTHORITY

*[Option 1 – no outsourcing of CIS of the contracting authority. The main criterion for the definition of outsourcing is the location of the CIS's hardware infrastructure. No outsourcing of information under the responsibility of the contracting authority is exclusively stored in the CIS hosted on the premises of contracting authority (incl. local or central data centres).]*

The contractor will not perform tasks for the contracting authority that include storing and processing contracting authority's information on a CIS that is provided on the basis of a contract with a third party contractor, under which the CIS is housed on premises different from the ones of the contracting authority.]

*[Option 2 – outsourcing of CIS of the contracting authority. The main criterion for the definition of outsourcing is the location of the CIS's hardware infrastructure. Outsourcing provisions apply for the contracts where information under the responsibility of the contracting authority is stored in the CIS hosted outside the premises of contracting authority (i.e. at externally located data centres, including public cloud). These provisions apply to all outsourced CIS environments, including production, test and development systems and any back-ups. Further, these provisions apply where information under the responsibility of the contracting authority is handled by an external system under a contract for services that includes the provision of an external software solution (e.g. a SaaS solution).]*

The contractor will perform tasks for the contracting authority that include storing and processing contracting authority's information on a CIS that is provided on the basis of a contract with a third-party contractor, under which the CIS is housed on premises different from those of the contracting authority.

If the contractor performs tasks that include storing and processing contracting authority information on a CIS of the contracting authority that is housed on non-EASA premises, the contractor and its personnel shall comply with the contracting authority's applicable security requirements.

For the Agency, the Agency's security rules adopted on the basis of Commission Decision (EU, Euratom) 2017/46 of 10 January 2017 on the security of communication and information

systems in the European Commission, its subsequent versions, its implementing rules (as adapted from time to time) and the corresponding security standards, guidelines and notices including Standard C(2020) 4190 under Decision (EU, Euratom) 2017/46 on Principles for outsourcing of communication and information systems.
While these Commission Decisions may serve as a benchmark, the Agency will inform the contractor of the rules applicable to the Agency at the time of execution of the contract.

# ANNEX I

# ETHICS REMINDER FOR SERVICE PROVIDERS EMPLOYED BY A CONTRACTOR OF THE EUROPEAN UNION AVIATION SAFETY AGENCY

**YOU ARE REMINDED THAT, AS A SERVICE PROVIDER EMPLOYED BY A COMPANY CONTRACTED BY THE EUROPEAN UNION AVIATION SAFETY AGENCY YOU MUST RESPECT THE ETHICAL PRINCIPLES AND OBLIGATIONS SET OUT BELOW.**

## I. Confidentiality of information and data protection

You must exercise the greatest discretion with regard to facts and information, whatever their source, that may come to your knowledge during the course of your provision of service to the Agency.

Without prejudice to the general obligation of professional secrecy, you must not disclose outside the Agency, in any way and by any means directly or through others, any information acquired in the course of your service provision. This restriction covers all notes, analyses, opinions, compilations, studies, interpretations, summaries, extracts, data or other documents or records in original or in copy containing, regarding, reflecting or otherwise deriving from any confidential, sensitive or secret information that you prepared or you became aware of in the exercise of your functions in the context of your work as a service provider that is not yet public or accessible to the public without any restriction (e.g. published on the internet, Europa or any other media, accessible for consultation).

In case you receive a device or IT account from the Agency for work purposes, you should be the sole user of that device/IT account. You should protect it at any time and notify immediately to the CISO any breach of security of a device or IT account.

In this context, you must also refrain from exploiting insights of a confidential nature in policy, strategy or internal processes that you may have acquired during your provision of service and that have not yet been made public or are not commonly available in the public domain.

You accept, without reservation, that you continue to be bound by these confidentiality obligations also after your period of service provision to the Agency.

## II. Contacts with other parties and publications

During your service provision, you shall not have any professional connections with third parties which might be incompatible with providing a service in the Agency (e.g. must not work for lobbyists, legal attachés, other firms or entities involved in EU-related matters in your field of work etc.).

You shall not have contact with the Press on matters relating to your work as a service provider in the Agency unless your employer and the Agency have agreed it beforehand.

You must not, alone or with others, publish or cause to be published any matter dealing with the work of the Agency without the written permission of your employer and the Agency. Such permission is subject to the conditions in force for all Agency staff.

Be aware that all rights, for any articles or other work done as part of your service provision to the Agency remain the property of the Agency in accordance with the contract signed by your employer and the Agency.

## III. Duty of loyalty

You are reminded that you should carry out the provision of service solely with the interests of your employer and their client, the Agency, in mind. You should neither seek nor take instructions from any other party in the context of your provision of service to the Agency.

You shall carry out the duties of service provision assigned to you objectively, impartially and in keeping with your duties of loyalty to your employer as a contractor with the Agency.

## IV. Conflict of interests during the period of service provision

You shall not, in the performance of your duties, deal with a matter in which, directly or indirectly, you have any personal interests such as to impair your independence, and, in particular, family and financial interests.

## V. Termination of service provision

Be aware that your employer and/or the Agency reserve their legal right to terminate or request the termination of your service provision and to pursue any person who does not respect the above-mentioned obligations and requirements.

**I have read and understood the contents of this reminder of the ethical principles and obligations that apply to me as an employee of contractor providing services to the Agency and undertake to respect them**

**Date & signature**